

Syntra – A Compliance Automation Tool

Project Team

Arsh Malik	21i-2752
Maheen Mansha	21i-1920
Laiba Shahid	21i-1552

Session 2021-2025

Supervised by

Dr. Muhammad Asim



Department of Computer Science

**National University of Computer and Emerging Sciences
Islamabad, Pakistan**

June, 2025

Contents

List of Figures	4
List of Tables	5
Introduction	6
1.1 Problem Statement	6
1.2 Scope	7
1.3 Modules	8
1.3.1 Module 1 (Controller)	8
1.3.2 Module 2 (Evidence Analyzer Module)	8
1.3.3 Module 3 (Report Generation)	8
1.3.2 Module 4 (Admin Panel Module)	9
1.3.2 Module 5 (Model Server Module)	9
1.3.2 Module 6 (Storage Module)	9
1.4 User Classes and Characteristics	10
Project Requirements	11
2.1 Use-Case (Use-Case Diagram + Detail Use Case)	11
2.1.1 Use-Case Diagram	11
2.1.2 High Level Use-Cases	12
2.1.3 Extended Use-Cases	15
2.2 Functional Requirements	26
2.2.1 Module 1 (Controller)	26
2.2.2 Module 2 (Evidence Analyzer Module)	26
2.2.3 Module 3 (Report Generation)	26
2.2.4 Module 4 (Admin Panel Module)	27
2.2.5 Module 5 (Model Server Module)	27
2.2.6 Module 6 (Storage Module)	27
2.3 Non-Functional Requirements	28
2.3.1 Reliability	28

2.3.2 Usability	28
2.3.3 Performance	29
2.3.4 Security	29
2.4 Domain Model.....	30
System Overview	31
3.1 Architecture Design	31
3.1.1 High Level Module Breakdown	31
3.1.2 Initial Design	33
3.1.3 Final Architecture Diagram.....	34
3.2 Design Models	34
3.2.1 Activity Diagram	34
3.2.2 Data Flow Diagram	36
3.2.2 System Sequence Diagram.....	38
3.3 Data Design	40
References	41

List of Figures

Figure 2. 1 Use-Case Diagram.....	11
Figure 2. 2 Domain Model.....	30
Figure 3. 1 Initial Architecture Design	33
Figure 3. 2 Final Architecture Diagram	34
Figure 3. 3 Activity Diagram	35
Figure 3. 4 Level 0 Data Flow Diagram	36
Figure 3. 5 Level 1 Data Flow Diagram	37
Figure 3. 6 System Sequence Diagram (Admin Side).....	38
Figure 3. 7 System Sequence Diagram (Admin Side).....	39
Figure 3. 8 Data Design (ERD)	40

List of Tables

Table 1. 1 User Classes and Characteristics	10
Table 2. 1 High Level Use Case 01	12
Table 2. 2 High Level Use Case 02	12
Table 2. 3 High Level Use Case 03	12
Table 2. 4 High Level Use Case 04	12
Table 2. 5 High Level Use Case 05	13
Table 2. 6 High Level Use Case 06	13
Table 2. 7 High Level Use Case 07	13
Table 2. 8 High Level Use Case 08	13
Table 2. 9 High Level Use Case 09	14
Table 2. 10 High Level Use Case 10	14
Table 2. 11 High Level Use Case 11	14
Table 2. 12 Extended Use Case 01	15
Table 2. 13 Extended Use Case 02	16
Table 2. 14 Extended Use Case 03	17
Table 2. 15 Extended Use Case 04	18
Table 2. 16 Extended Use Case 05	19
Table 2. 17 Extended Use Case 06	20
Table 2. 18 Extended Use Case 07	21
Table 2. 19 Extended Use Case 08	22
Table 2. 20 Extended Use Case 09	23
Table 2. 21 Extended Use Case 10	24
Table 2. 22 Extended Use Case 11	25

Chapter 1

Introduction

This report defines the needs of Syntra. This is a tool for compliance automation, and its intended use is specifically focused on ISO 27001, to reduce the complexity required in compliance verification and mitigation efforts. Several compliance management tasks are automated by Syntra so that manual efforts through people may be minimized and there will be minimal possibilities of non-compliance. The effort to meet international standards shall also be simplified. The following types of readers may be targeted through the following document:

- **Developers:** Who would develop and maintain the tool according to the given requirements.
- **Compliance Officers/Managers:** The key users of Syntra and who would interact with the tool for managing compliance efforts.
- **Users (Compliance Managers, Admins, Control Handlers):** To know how the tool will help them efficiently manage their compliance efforts.
- **Testers:** For the functionality of the tool by running test cases and validating its compliance with the mentioned requirements.
- **Documentation Writers:** Prepare guides and manuals as described in this document, referring to the specifications and functionalities.

1.1 Problem Statement

Compliance management, in many organizations, remains largely a very manual process around the world and particularly so in Pakistan. This results in inefficiency, error, and delay, all of which increase the risk of not making the critical standards like ISO 27001. Compliance managers are mostly dependent on such tools as spreadsheets, emails, and evidence collection via surveys, all of which are time-consuming, and also prone to human error. These factors expose the organization to financial, legal, and reputational risks. Most of the compliance solutions available are also very expensive, thus making them inaccessible to the smaller organizations that would appreciate them most.

SYNTRA solves all these problems by automating key compliance tasks including control assignment, evidence collection, gap and risk analysis, and reporting. SYNTRA thereby reduces the time and effort involved in compliance management and minimizes the possibility of errors, thus making the entire process much more efficient, cost-effective, and reliable.

1.2 Scope

SYNTRA focused on automating compliance management tasks, especially those in line with the ISO 27001 standards. The system actually allows organizations to be registered by the compliance managers themselves; these managers will then input information such as the domain of the organization, the personnel involved, and services given, after which they would be given their customized Statement of Applicability, or SoA.

The controls are divided into two; that is, technical controls, and the other is non-technical; the former are validated through MDM technology while the latter by submitting evidence. The tool automates assignments of the controls, sends e-mail notifications to the control handlers, and an interface for submitting evidence and gap assessment. Upon detection of non-compliance, the system triggers mitigation plans. The tool also generates executive and technical reports.

First and foremost, the main purpose is to reduce time, effort, and errors in achieving compliance and, therefore, increase the cost-effectiveness of this process for organizations. The initial implementation will include only ISO 27001, but future plans will be to expand towards other standards and introduce other features, such as cost and predictive analysis. SYNTRA does not give legal certification that proves the organization's compliance, but it helps a lot in this process within an organization.

1.3 Modules

The compliance automation tool of SYNTRA consists of several modules, each assigned with different aspects of compliance management. There are two major system types divided among the modules: Client Web App and Admin Web App.

The Client Web App was designed for compliance managers and control handlers to be well taken care of by the compliance automation tool to provide a user-friendly interface in handling compliance tasks effectively.

1.3.1 Module 1 (Controller)

This central module manages control assignment, evidence collection, gap and risk analysis. It enables interaction with controls and streamlines the compliance process.

Assigns controls and manages the evidence submission and mitigation phases.

- Allows interactive selection of controls and role assignments for the control owner, custodian, and tester.
- Provides input validation checks to ensure proper evidence submission.
- Automates deadline and reminder notices, including control owners and custodians' alerts
- Allows campaigns to be created, edited and managed with automatic e-mail notifications to control handlers

1.3.2 Module 2 (Evidence Analyzer Module)

This module validates the evidence submitted, performs real-time gap and risk assessment and provides analyses of compliance against the selected standards.

- It performs real-time gap and risk assessment based on the submitted evidence.
- Analyzes evidence of compliance, determining the overall level of compliance.
- Activates the phase of mitigation when there is a signaled non-compliance, providing actionable insights and guidelines.

1.3.3 Module 3 (Report Generation)

The reporting module comes up with detailed report on the status of compliance for the technical staff and even higher management.

- Produces technical reports to analyze in detail.
- Creates executive reports summarizing the overall compliance status.

The Admin Web App is designed to make the job of handling the compliance tool easier and provides oversight in the process, ensuring proper controls and users are managed properly.

1.3.2 Module 4 (Admin Panel Module)

This module enables administrators to manage compliance controls, standards, as well as users. For instance, admins may be able to look at the results that have been generated by the model and make necessary adjustments.

- It has an approval procedure for controls and standards before they are made available in the database.
- It extracts appropriate controls, evidence requirements, and other information from standards (e.g., ISO 27001) using the Phi 3.5 model.

1.3.2 Module 5 (Model Server Module)

This module stores the machine learning model. The model takes evidence and provides feedback.

- It integrates well with the other modules to induce multiple activities due to the compliance status.
- It validates evidence and creates feedback against compliance with the chosen standard.
- It gives an insight of controls and evidence necessary to be in place regarding the standard input.

1.3.2 Module 6 (Storage Module)

This module ensures that the user-submitted evidence submitted for analysis will be kept safe for future use.

- Helps retrieval of evidence files to make it easier in accessing them when they are required to be used during an analysis of compliance.

1.4 User Classes and Characteristics

SYNTRA The automation tool is designed for many classes of users, each with distinct responsibilities and needs for interaction. A description of the different classes of users and their key characteristics follows:

User class	Description
Compliance Manager	The primary user that oversees compliance initiatives in an organization. They monitor campaigns, assign controls, track progress, and review the outcomes of compliance. The Compliance Managers are well-versed in standards such as ISO 27001 and may be able to give opinions on evidence and controls.
Control Handler	Individuals assigned to various compliance controls within the organization. In this, they will be Control Owners, Custodians, or Testers and are held responsible for submitting evidence, completing gap assessments, and ensuring that all controls meet the set standards of compliance.
Admin	This is the admin responsible for managing and keeping the overall functionality of the compliance tool. In it, Admins have an update on the standards, manage controls, and keep the tool running. They need to have a keen understanding of how things are done in compliance but also master some technical skills.
Tester	Users who test the software on the given requirements stated in the documentation and make sure the tool works as expected. They ensure all the functions of the system work correctly and at the necessary quality level.
Developers	The technical group which develops, maintains and implements the compliance tool. Developers closely work on the requirement and ensure that the system is functional and efficient for any user classes.
Auditors/ Reviewers	External or internal personnel who assess the extent to which an organization conforms to standards. Auditors utilize the system to conduct examinations on reports, verify evidence and controls and provide instant feedback in a compliance audit or assessment. They require easy access to detailed reports and evidence.

Table 1. 1 User Classes and Characteristics

Chapter 2

Project Requirements

In this chapter, project requirements are defined in terms of functional and non-functional requirements for developing the **SYNTRA**. These requirements can be said to be one of the most basic concepts defining a system's behavior, performance, or constraints.

2.1 Use-Case (Use-Case Diagram + Detail Use Case)

This section will introduce the requirements gathering method based on the nature of our project. Since **SYNTRA** contains interactive functionalities for its end-users, the Use Case Diagrams and Use Cases are very relevant.

2.1.1 Use-Case Diagram

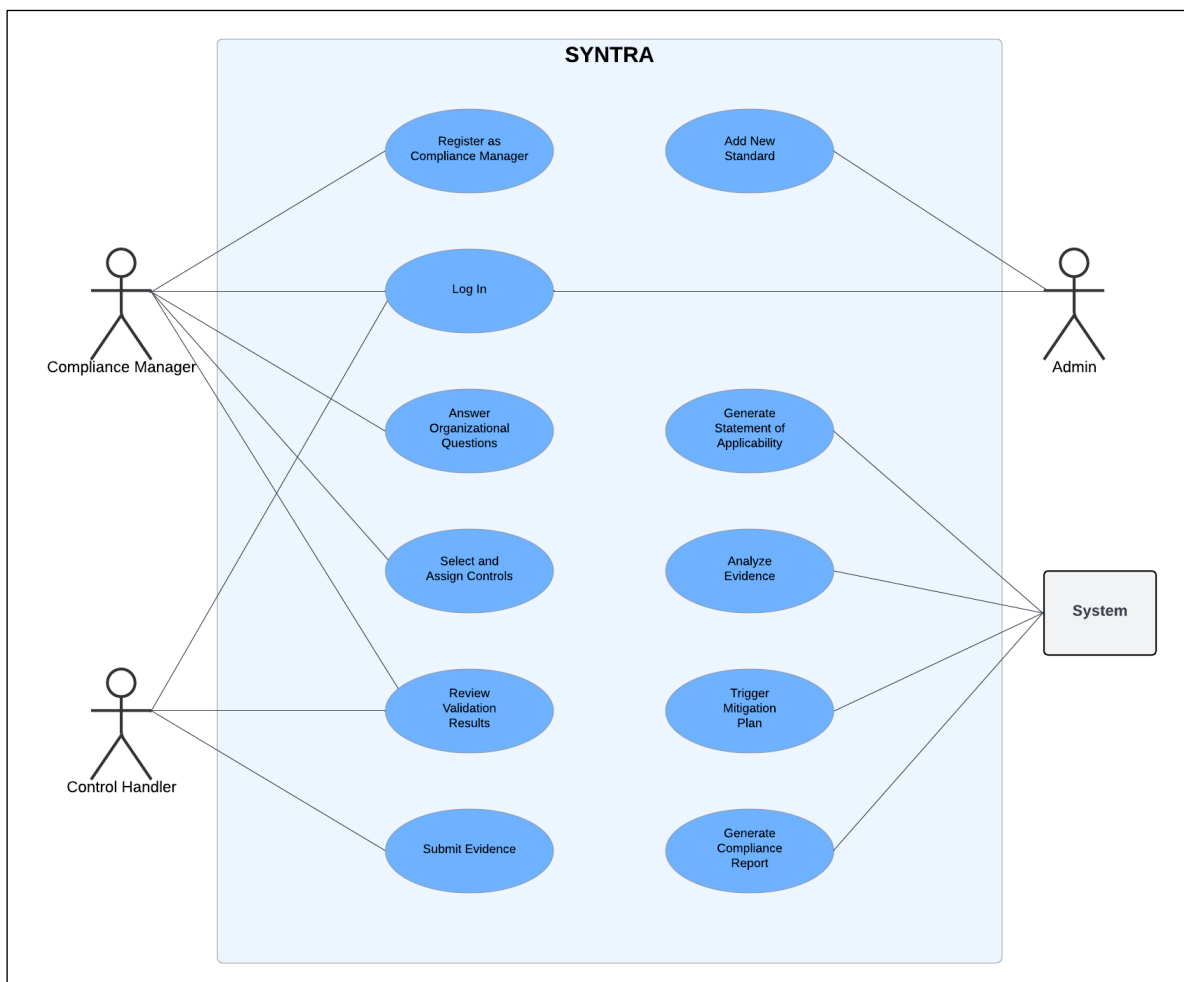


Figure 2. 1 Use-Case Diagram

2.1.2 High Level Use-Cases

Table 2. 1 High Level Use Case 01

Use Case ID	UC1
Use Case	Register as Compliance Manager
Actors	Compliance Manager
Type	User Goal
Description	Allows a compliance manager to register and create an account in the system.

Table 2. 2 High Level Use Case 02

Use Case ID	UC2
Use Case	Log In
Actors	Compliance Manager, Control Handler, Admin
Type	User Goal
Description	The actor logs into the SYNTRA platform to perform their respective tasks.

Table 2. 3 High Level Use Case 03

Use Case ID	UC3
Use Case	Answer Organizational Questions
Actors	Compliance Manager
Type	User Goal
Description	The Compliance Manager answers questions about their organization to generate a Statement of Applicability (SoA).

Table 2. 4 High Level Use Case 04

Use Case ID	UC4
Use Case	Generate Statement of Applicability (SoA)
Actors	System
Type	System Function
Description	The system generates a Statement of Applicability report based on the organization's input, showing applicable controls.

Table 2. 5 High Level Use Case 05

Use Case ID	UC5
Use Case	Select and Assign Controls
Actors	Compliance Manager
Type	User Goal
Description	Compliance manager selects controls via drag-and-drop functionality and assigns those controls to control handlers.

Table 2. 6 High Level Use Case 06

Use Case ID	UC6
Use Case	Submit Evidence
Actors	Control Handler
Type	User Goal
Description	Control handler submits evidence related to the assigned controls.

Table 2. 7 High Level Use Case 07

Use Case ID	UC7
Use Case	Analyze Evidence
Actors	System
Type	System Function
Description	The system performs gap and risk assessments on the submitted evidence.

Table 2. 8 High Level Use Case 08

Use Case ID	UC8
Use Case	Review Validation Results
Actors	Control Handler (CH), Compliance Manager (CM)
Type	User Goal
Description	Compliance Manager and Control Handler review the results of evidence validation.

Table 2. 9 High Level Use Case 09

Use Case ID	UC9
Use Case	Trigger Mitigation Plan
Actors	System, Control Handler (CH)
Type	System Function
Description	If evidence fails validation, the system triggers a mitigation plan for the CH to implement.

Table 2. 10 High Level Use Case 10

Use Case ID	UC10
Use Case	Generate Compliance Report
Actors	System
Type	System Function
Description	The system generates and stores a compliance report after successful validation.

Table 2. 11 High Level Use Case 11

Use Case ID	UC11
Use Case	Add New Standard
Actors	Admin
Type	Admin Function
Description	The admin adds a new compliance standard, and the system extracts relevant controls and test plans.

2.1.3 Extended Use-Cases

Table 2. 12 Extended Use Case 01

Use Case UC1	
Use Case Name	Register as Compliance Manager
Scope	SYNTRA Compliance Automation Tool
Level	User Goal
Primary Actor	Compliance Manager
Stakeholders & Interests	Compliance Manager wants to be able to use the system to manage compliance for their organization.
Preconditions	The user must have valid credentials & access to the registration page.
Success Guarantee (Postconditions)	The compliance manager successfully registers and can log into the system.
Main Success Scenario	• The compliance manager visits the registration page. • The manager provides required information (name, email, password). • The manager submits the registration form. • The system verifies the provided data and registers the Compliance Manager. • Compliance Manager receives a confirmation email. • The manager confirms the email to activate the account. • CM can log in to the system using their credentials.
Extensions	• E1: Invalid email format → The system displays an error message, prompting the user to correct it. • E2: Network failure → Registration is saved in a queue, and the CM is informed of the delay. • E3: If required fields are missing → The system prompts the CM to complete the missing information.
Special Requirements	Email verification should occur to ensure account security. The system should provide a user-friendly registration form with input validation.
Technology & Data Variation List	CM could register using different methods such as SSO or filling out forms manually.

Table 2. 13 Extended Use Case 02

Use Case UC2	
Use Case Name	User Log In
Scope	SYNTRA Compliance Automation Tool
Level	User Goal
Primary Actor	Compliance Manager (CM), Control Handler (CH), Admin
Stakeholders & Interests	Actors wants to access the platform to perform their assigned tasks.
Preconditions	The user must be registered in the system.
Success Guarantee (Postconditions)	The user is authenticated and granted access to the system.
Main Success Scenario	• User navigates to the login page. • User provides valid login credentials (e.g., email and password) or SSO. • The system authenticates the user and grants access to the platform.
Extensions	• E1: If the login credentials are invalid → The system displays an error message and prompts the user to re-enter credentials. • E2: If the account is locked → The system informs the user and provides a way to unlock the account. • E3: If there is a network failure → The system prompts the user to try again later..
Special Requirements	The login system must use encryption to protect user credentials.
Technology & Data Variation List	User may log in using different methods, such as SSO or OAuth-based login.

Table 2. 14 Extended Use Case 03

Use Case UC3	
Use Case Name	Answer Organizational Questions
Scope	SYNTRA Compliance Automation Tool
Level	User Goal
Primary Actor	Compliance Manager (CM)
Stakeholders & Interests	Compliance Manager wants to provide accurate organizational information to generate the SoA report.
Preconditions	The compliance manager must be logged into the system.
Success Guarantee (Postconditions)	The organization's details are successfully captured and forwarded for SoA generation.
Main Success Scenario	• The system prompts the CM with a series of questions about the organization (e.g., domain, standard, region, etc.). • The CM answers all questions and submits the information. • The system validates the responses. • The information is forwarded to the controller for processing.
Extensions	• E1: If the answers are incomplete → The system prompts the CM to complete missing fields. • E2: If the system detects invalid input formats → The system requests the CM to correct the inputs. • E3: If there is a network failure → The system saves the progress and prompts the CM to retry later.
Special Requirements	The system should have responsive input forms and validation logic to ensure accuracy.
Technology & Data Variation List	Data submission can be done through forms or file uploads (e.g., CSV for employee details).

Table 2. 15 Extended Use Case 04

Use Case UC4	
Use Case Name	Generate Statement of Applicability (SoA)
Scope	SYNTRA Compliance Automation Tool
Level	System function
Primary Actor	System
Stakeholders & Interests	Compliance Manager needs a report to understand applicable controls.
Preconditions	The Compliance Manager has completed organizational questions.
Success Guarantee (Postconditions)	A Statement of Applicability (SoA) report is generated and sent to the Compliance Manager.
Main Success Scenario	• The system receives organizational details. • The controller forwards the details to the Phi 3.5 model. • The model generates the SoA report, listing applicable controls and associated risks. • The system sends the SoA report to the CM for review.
Extensions	• E1: If the model fails to generate the SoA → The system retries or informs the admin. • E2: If network issues prevent SoA delivery → The system queues the SoA report for later delivery.
Special Requirements	The SoA generation process should be optimized for performance and accuracy.
Technology & Data Variation List	The SoA could be delivered in different formats (e.g., PDF, JSON).

Table 2. 16 Extended Use Case 05

Use Case UC5	
Use Case Name	Select and Assign Controls
Scope	SYNTRA Compliance Automation Tool
Level	User Goal
Primary Actor	Compliance Manager (CM)
Stakeholders & Interests	Compliance Manager wants to select relevant controls and assign them to Control Handlers. Control Handlers want clear information about assigned controls.
Preconditions	The Compliance Manager has reviewed the SoA report.
Success Guarantee (Postconditions)	Controls are selected and successfully assigned to CHs.
Main Success Scenario	• Compliance Manager reviews the SoA report and selects applicable controls. • Compliance Manager assigns controls to Control Handlers by providing their details (e.g., name, email). • The system saves the assignments and sends notification emails to Control Handlers.
Extensions	• E1: If the CM provides incomplete CH details → The system prompts the CM to complete the information. • E2: If the email server fails → The system retries sending the notification or alerts the admin.
Special Requirements	The system should provide an intuitive interface for control selection (e.g., drag-and-drop).
Technology & Data Variation List	CH assignments could be managed via bulk upload or manual entry.

Table 2. 17 Extended Use Case 06

Use Case UC6	
Use Case Name	Submit Evidence
Scope	SYNTRA Compliance Automation Tool
Level	User Goal
Primary Actor	Control Handler (CH)
Stakeholders & Interests	Control Handler needs to upload evidence for the assigned controls and Compliance Manager needs evidence to be submitted for compliance verification.
Preconditions	The control handler is logged in and has access to the assigned controls.
Success Guarantee (Postconditions)	The evidence is successfully submitted, validated, and stored.
Main Success Scenario	• CH logs in and views their assigned controls. • CH uploads evidence files for each control. • The system validates the format and completeness of the evidence. • CH receives a confirmation of successful submission.
Extensions	• E1: If the evidence file format is invalid → The system rejects the submission and prompts CH to upload a valid file. • E2: If a high-priority evidence file is missing → The system triggers the mitigation phase. • E3: If the upload fails due to a network issue → The system prompts CH to retry.
Special Requirements	The system should support multiple file formats and ensure secure data transfer.
Technology & Data Variation List	Evidence could be submitted in formats like PDF, CSV, or images, depending on the control requirements.

Table 2. 18 Extended Use Case 07

Use Case UC7	
Use Case Name	Analyze Evidence
Scope	SYNTRA Compliance Automation Tool
Level	System function
Primary Actor	System
Stakeholders & Interests	Control Handler wants their evidence to be analyzed accurately and quickly while Compliance Manager needs accurate evidence validation for decision-making.
Preconditions	The evidence has been submitted by the Control Handler.
Success Guarantee (Postconditions)	The evidence is validated, and results are provided.
Main Success Scenario	• The system analyzes the submitted evidence using the Phi 3.5 model. • The analyzer checks compliance with selected standards and flags gaps or risks. • The results are stored and made available for review.
Extensions	• E1: If the analysis model fails → The system retries or escalates to an admin for manual review. • E2: If evidence is incomplete or non-compliant → The system triggers the mitigation phase and informs the CH.
Special Requirements	The analyzer must handle a large volume of evidence efficiently.
Technology & Data Variation List	Analysis could involve real-time API calls to external systems or internal validation algorithms.

Table 2. 19 Extended Use Case 08

Use Case UC8	
Use Case Name	Review Compliance Results
Scope	SYNTRA Compliance Automation Tool
Level	User Goal
Primary Actor	Compliance Manager (CM), Control Handler (CH)
Stakeholders & Interests	Compliance Manager needs to review evidence results to confirm compliance or trigger mitigation and Control Handler needs feedback on the submitted evidence.
Preconditions	The evidence has been analyzed.
Success Guarantee (Postconditions)	The results are reviewed, and compliance decisions are made.
Main Success Scenario	• The CM/CH logs in and views the results of the evidence analysis. • The CM decides whether the control is compliant or requires mitigation. • If compliant, the system marks the control as completed. • If non-compliant, the system triggers the mitigation phase.
Extensions	• E1: If the results are unclear → The CM/CH can request a re-analysis. • E2: If the control fails → The system assigns a mitigation plan with deadlines.
Special Requirements	The system should provide clear feedback and actionable insights from the analysis.
Technology & Data Variation List	The results could be displayed as reports or visual dashboards.

Table 2. 20 Extended Use Case 09

Use Case UC9	
Use Case Name	Trigger Mitigation Phase
Scope	SYNTRA Compliance Automation Tool
Level	System function
Primary Actor	System
Stakeholders & Interests	Compliance Manager wants to ensure that non-compliant controls are addressed & Control Handler needs to resolve compliance gaps in a timely manner.
Preconditions	Non-compliance has been detected during evidence analysis.
Success Guarantee (Postconditions)	A mitigation plan is created and assigned, and the issue is resolved within the deadline.
Main Success Scenario	• The system identifies non-compliance during evidence analysis. • The system generates a mitigation plan with deadlines. • The mitigation plan is assigned to the CH. • The system sends notification emails with detailed instructions. • The CH works on the mitigation plan and resubmits the evidence. • The system validates the new evidence.
Extensions	• E1: If the CH fails to meet the deadline → The system escalates the issue to the CM. • E2: If the evidence is still non-compliant after mitigation → The system retries with a new plan or escalates.
Special Requirements	The system should automatically track deadlines and escalate issues as needed.
Technology & Data Variation List	The mitigation plan could include automated tasks or require manual intervention.

Table 2. 21 Extended Use Case 10

Use Case UC10	
Use Case Name	Generate Compliance Report
Scope	SYNTRA Compliance Automation Tool
Level	System function
Primary Actor	System
Stakeholders & Interests	Compliance Managers (CMs) require compliance reports to confirm the organization's adherence to standards, while Control Handlers (CHs) may need detailed reports on specific controls.
Preconditions	All evidence has been submitted, analyzed, and validated; all necessary approvals have been completed.
Success Guarantee (Postconditions)	A comprehensive compliance report is generated and stored, with the option for users to download or view it.
Main Success Scenario	• The system detects the completion of evidence validation and compiles data on gaps, risks, and mitigations. • Two reports are generated: ○ Technical Report: Detailed control compliance and risk analysis. ○ Executive Report: Summary of compliance status and organizational impact. • Reports are stored in the database, and the system notifies the CM and stakeholders of availability. • CM or authorized users can access and download the reports.
Extensions	• E1: If a system failure occurs during report generation → the system retries or logs the failure for admin investigation. • E2: If data inconsistencies are detected → the system flags the issue and notifies the admin to resolve it before proceeding with report generation.
Special Requirements	Reports must be generated in both human-readable (e.g., PDF) and machine-readable (e.g., JSON) formats, securely stored in the database, and accessible only to authorized users.
Technology & Data Variation List	The reports can be exported in different formats (e.g., PDF, CSV, XML) depending on user needs.

Table 2. 22 Extended Use Case 11

Use Case UC11	
Use Case Name	Add New Standard
Scope	SYNTRA Compliance Automation Tool
Level	Admin function
Primary Actor	Admin
Stakeholders & Interests	Admin needs to ensure that the SYNTRA system remains up to date with the latest compliance standards, controls, and test plans. Compliance Manager (CM) relies on the system to have accurate and up-to-date standards for compliance purposes.
Preconditions	The new compliance standard is available in a format that the system can process (e.g., document, dataset).
Success Guarantee (Postconditions)	The new compliance standard is successfully added, including controls, evidence, test plans, and mitigation plans, and is ready for use in the compliance process.
Main Success Scenario	• The admin logs in and navigates to "Add New Standard." • They upload the compliance standard document or provide a link to an external source. • The system processes the document and extracts relevant controls, evidence, and test plans. • The extracted information is presented to the admin for review. • The admin reviews, edits if needed, and approves the extracted content. • The system stores the new standard in the database and notifies the admin of successful addition.
Extensions	• E2: If extraction fails, the system logs the error and prompts a retry or manual input. • E3: If the admin rejects the extraction, the system allows for edits and reprocessing before saving.
Special Requirements	The system must support multiple document formats (e.g., PDF, Word, XML) for compliance standards and ensure accurate, complete information extraction with robust data processing algorithms.
Technology & Data Variation List	The system may support batch processing for multiple standards and offer different file formats for import (e.g., JSON, XML, DOCX).

2.2 Functional Requirements

This section describes the functional requirements for the SYNTRA compliance automation tool. The requirements are grouped by module, which is divided into specific functional requirements that describe the features and functionalities of the system.

2.2.1 Module 1 (Controller)

- **FR1:** The system shall enable compliance managers to create and manage compliance campaigns.
- **FR2:** The system shall enable the control owners, custodians, and testers assignment to be made by the compliance managers.
- **FR3:** The system shall be having an interactive interface for selection of controls.
- **FR4:** The system shall automate to send alerts/notifications as well as reminders to the custodians and control owners regarding their tasks and deadlines.
- **FR5:** The system shall have an interface for evidence submission by proper validation checks for input to ensure valid types are submitted as well as not empty submissions.
- **FR7:** The system shall allow submission of evidence by control handlers to assigned controls.
- **FR8:** In the event of non-compliance identified, the system shall be able to enable the mitigation phase.

2.2.2 Module 2 (Evidence Analyzer Module)

- **FR1:** The system shall accept submitted evidence and validate it against the chosen compliance standards that may be, for example, ISO 27001.
- **FR2:** The system shall perform real-time gap assessments from the submitted evidence.
- **FR3:** The system shall analyze evidence about compliance and return the level of compliance.
- **FR4:** The system shall trigger the mitigation phase in the event of detected non-compliance, with recommendations for action.
- **FR5:** The system should display status on submitted evidence

2.2.3 Module 3 (Report Generation)

- **FR1:** Technical reports for closer look at the compliance status
- **FR2:** The system shall produce executive reports summarizing total compliance status
- **FR3:** The system shall export the produced reports in different formats, such as PDF and CSV formats.

2.2.4 Module 4 (Admin Panel Module)

- **FR1:** The system should support adding, updating, and deletion of compliance controls based on changes in the standards.
- **FR2:** The system should have admin approvals control with prior standard, in case storing data into the database
- **FR3:** System should provide an admin feature to review and validate the results from model server
- **FR4:** The system should allow the facility for the same admin on user's accounts management: create, update and deactivate a user's role

2.2.5 Module 5 (Model Server Module)

- **FR1:** Interface with other modules so that compliance status shall trigger further activities
- **FR2:** The system shall validate evidence and give output through feedback using the input evidence
- **FR3:** The system shall provide the output of giving feedback relating to controls and evidence needed through standards input, wherein the remarks should be elaborated in the results
- **FR4:** The system shall analyze evidence submission made, and follow-up action shall determine if it is required.
- **FR5:** The system shall extract pertinent controls, requirements of evidence, and other information from the compliance standards, for example, ISO 27001 by using LLM models.

2.2.6 Module 6 (Storage Module)

- **FR1:** The system shall ensure secure file storage of the evidence files submitted by the user for future analysis.
- **FR2:** The system shall allow retrieval of stored evidence files
- **FR3:** The system shall ensure version control of evidence files to track changes in evidence files.
- **FR4.** The system shall have data encryption in all stored evidence files to preserve their confidentiality and integrity.

2.3 Non-Functional Requirements

This section focuses on the non-functional requirements in terms of the quality attributes of the SYNTRA compliance automation tool.

2.3.1 Reliability

The reliability of SYNTRA is critical to ensure that Compliance Managers can depend on the system for accurate compliance tracking and reporting.

- **REL-1:** The system shall have a mean time between failures of at least 1,000 hours for high reliability during operation
- **REL-2:** On occurrence of failure due to software, the system shall provide an automatic recovery facility to restore the last known stable state within 5 minutes.
- **REL-3:** The system shall record all errors and failures in a specific error log for subsequent study and analysis, hence facilitating effective troubleshooting.
- **REL-4:** The system shall contain an error detection policy that notifies the administrators concerning the failures that have occurred within 2 minutes of the happening, thus enabling adequate and prompt response.

2.3.2 Usability

Usability is key to ensuring that all user classes (Compliance Managers, Control Handlers, Admins) can effectively interact with SYNTRA.

- **USE-1:** The system shall offer an interface with which compliance managers can accomplish tasks through no more than three clicks.
- **USE-2:** The system shall simplify the uploading and submission of evidence process with a drag-and-drop interface reducing user error.
- **USE-3:** The system shall use contextual help and tooltips on all user interface elements to aid the users' comprehension of the application.
- **USE-4:** The system shall ensure accessibility for people with disabilities as specified in Web Content Accessibility Guidelines (WCAG) 2.1 Level AA standards.

2.3.3 Performance

Performance requirements ensure that SYNTRA operates efficiently under different load conditions.

- **PER-1:** For 95% of evidence submissions, the system shall process submissions and report validation results in less than 5 seconds.
- **PER-2:** The system shall support concurrent users in at least numbers of 100 without degradation in performance to provide for responsiveness and availability.
- **PER-3:** The system shall provide compliance reports in less than 10 seconds for average requests, ensuring timely access to information required.
- **PER-4:** The response time of the system shall be less than 3 seconds for all actions related to user interfaces such as navigation from one page to the next or submitting forms.

2.3.4 Security

Security is paramount given the sensitive nature of compliance data.

- **SEC-1:** The system shall restrict access to highly classified information with a security level of 99.9% of the system against the unauthorized access attempt.
- **SEC-2:** The system shall need multi-factor authentication to all users for better access control and prevent unauthorized entry.
- **SEC-3:** The system shall protect all sensitive data through industry standardized encryption algorithms in transit and rest, thereby ensuring confidentiality.
- **SEC-4:** The system will conduct a quarterly security audit of the vulnerably and correct it to be assured of following the set standards and regulations on security.

2.4 Domain Model

The domain model for SYNTRA will represent the key entities, relationships, and data flows within the system. The domain model will serve as a blueprint for understanding how the various components of the system relate to each other and how data moves through the system during operations.

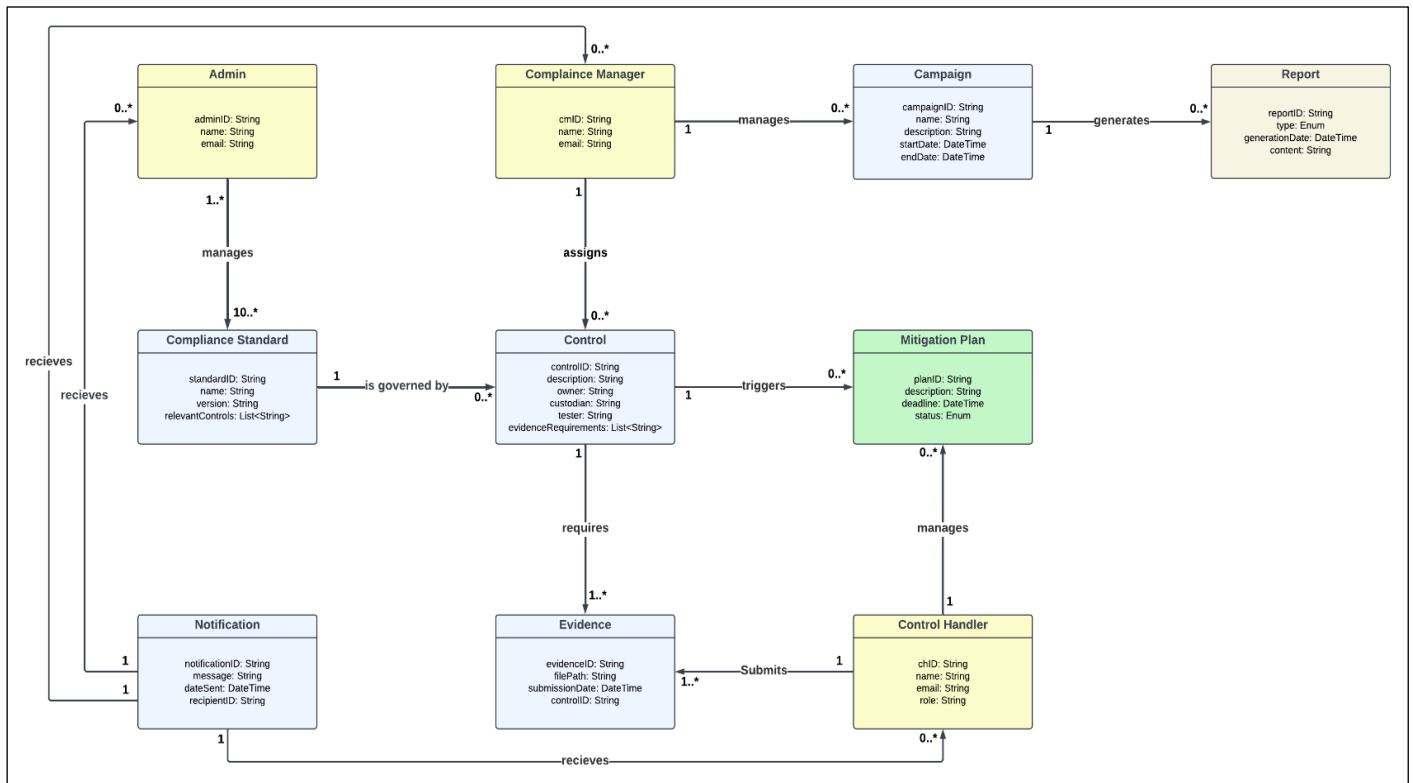


Figure 2. 2 Domain Model

Chapter 3

System Overview

SYNTRA Compliance Automation Tool streamlines compliance management of the organization in terms of ISO 27001/ISO 27002 standards (for now). This manages the processes of control assignment, evidence collection, analysis, and reporting. Thus, it acts as a highly effective solution for compliance managers and control handlers. The tool verifies evidence along with its analysis of compliance gaps using small language model Phi 3.5. The system basically has two major interfaces:

- The Client Web App - whereby compliance managers will manage compliance activities,
- The Admin Web App - whereby administrators manage standards and controls applied in compliance campaigns.

Its architecture supports modularity and scalability, ensuring effective communication among components like the Controller, Evidence Analyzer, Phi 3.5 model, and databases. It features cloud storage for holding evidence files and is preinstalled with a reporting dashboard that can post compliance statuses and analytics.

3.1 Architecture Design

The architecture pattern SYNTRA Compliance Automation Tool is multi-tiered, and the elements are grouped based on functionality and communicate through well-defined interfaces. The system is decomposed into several interrelated modules that cooperate to achieve full compliance automation, from assignment of controls through evidence analysis to reporting.

3.1.1 High Level Module Breakdown

At a high level, the architecture could be broken down in the following modules:

1. Controller Module:

This module acts as a communication node that receives inputs from the compliance manager, which entails organizational domain details and selected compliance standards, and sends them on to the appropriate subsystems. The controller also handles information flow between the Evidence Analyzer, the Phi 3.5 Model, the Database, and the Email Server. It initiates evidence requests, controls assignments, and produces reports.

2. Evidence Analyzer Module:

It checks and analyses the evidence submitted to it by control handlers. After uploading evidence, this module evaluates evidence against one of the chosen compliance standards with pre-defined adequacy criteria. Results are then passed on to the Controller.

3. Phi 3.5 Model Module:

The Phi 3.5 Model does natural language processing to parse compliance standards and extract the relevant controls. It will also validate evidence submitted at a deeper level to ensure that the submitted evidence is in compliance with the specific controls mentioned in the standard. This module works by interacting with both Database (for retrieving and storing parsed results) and the Evidence Analyzer (in real-time to analyze the evidence).

4. Database Module:

It will provide an encrypted repository to store the compliance result with the parsing done and the user-uploaded evidence files. It will further communicate with the Controller and Phi 3.5 Model for data pull and transfer. The Database will ensure that any control related data and the user-uploaded evidence be stored in a way that may be recovered anytime and analyzed.

5. Dashboard and Reporting Module:

The Dashboard provides compliance managers with a high-level overview of the status of compliance, presenting key metrics and results. It pulls information from the Controller and renders it in an easily consumable format. Reporting allows compliance managers to view and download more detailed compliance reports that detail evidence submissions and control validations.

6. Email Server Module:

This module deals with all communications related to the system that transpire between the system and the users. It sends reminders and notices to control handlers in regard to evidence submission and reminds the compliance manager of the compliance statuses and deadlines.

7. Control Handlers

These are the end-users who are required to file evidence based on controls assigned to them. The control handlers get alerts and file evidence through the Client Web App, which is then analyzed by the Evidence Analyzer and the Phi 3.5 Model.

System Interactions:

- The **Compliance Manager** inputs the domain of the organization and retrieves the compliance standard (**Step 1 in Figure**). This is communicated to the **Controller**, which triggers the **Phi 3.5 Model** to generate a Statement of Applicability (SoA) (**Step 4**).
- Using the SoA, the Controller assigns controls and control responsibilities to control handlers (**Step 5**).
- For the **Control Handlers**, they must wait on receiving emails from the **Email Server** in **step 7**. Then, it proceeds to upload evidence via **Steps 8 and 9**.
- **Evidence Analyzer** and Phi 3.5 Model validate the uploaded evidence via **Steps 10-12**.
- Then, the controller uploads compliance results in **Dashboard and Reports** for the compliance manager to view and download via **Steps 13 and 14**.

Architecture is ensured so that all modules interoperate harmoniously toward automation of compliance processes, reduction in the manual effort, and accuracy in the validation of compliance. Modular development ensured flexibility and scalability in adapting to various standards of compliance and organizational needs.

3.1.2 Initial Design

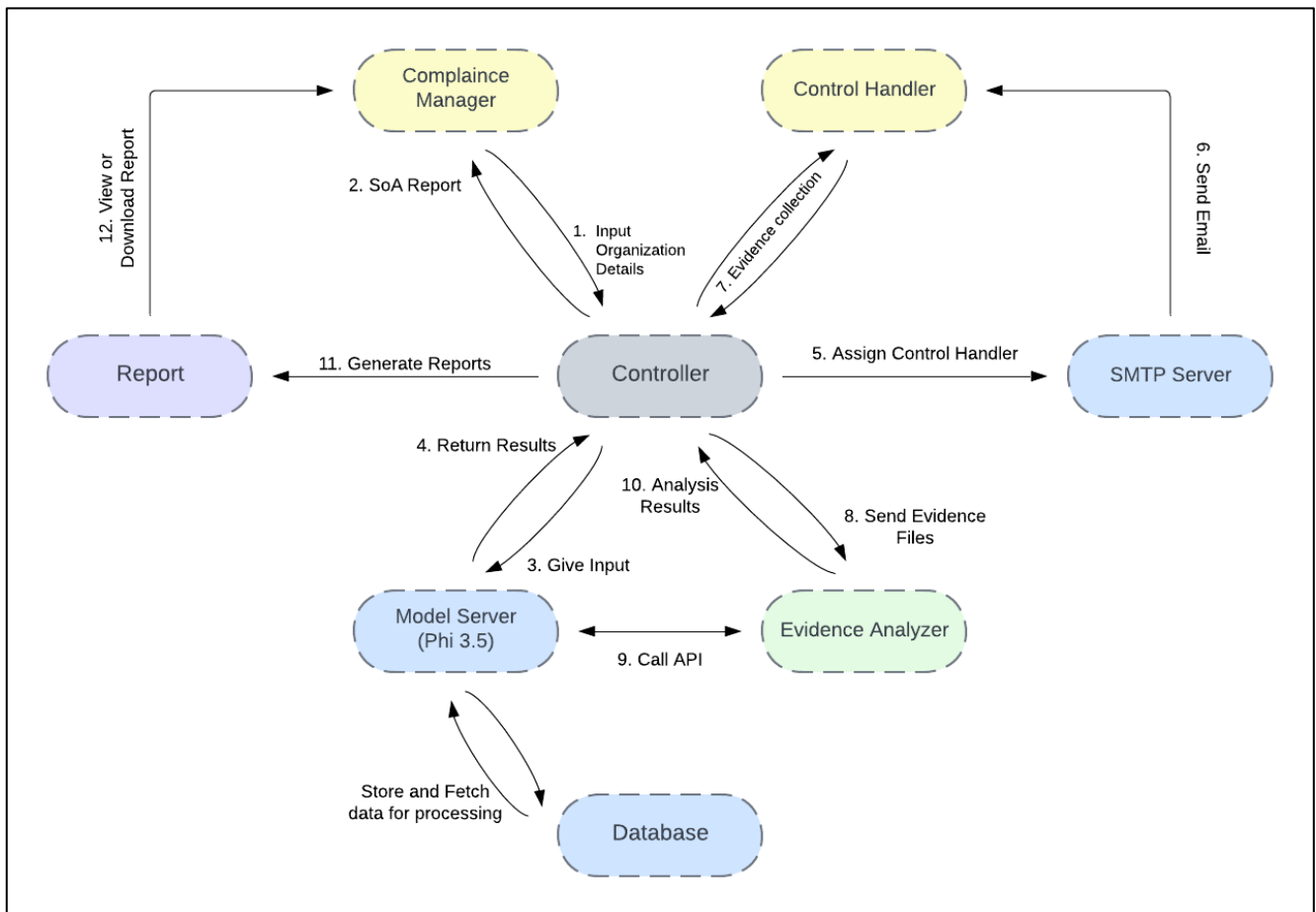


Figure 3. 1 Initial Architecture Design

3.1.3 Final Architecture Diagram

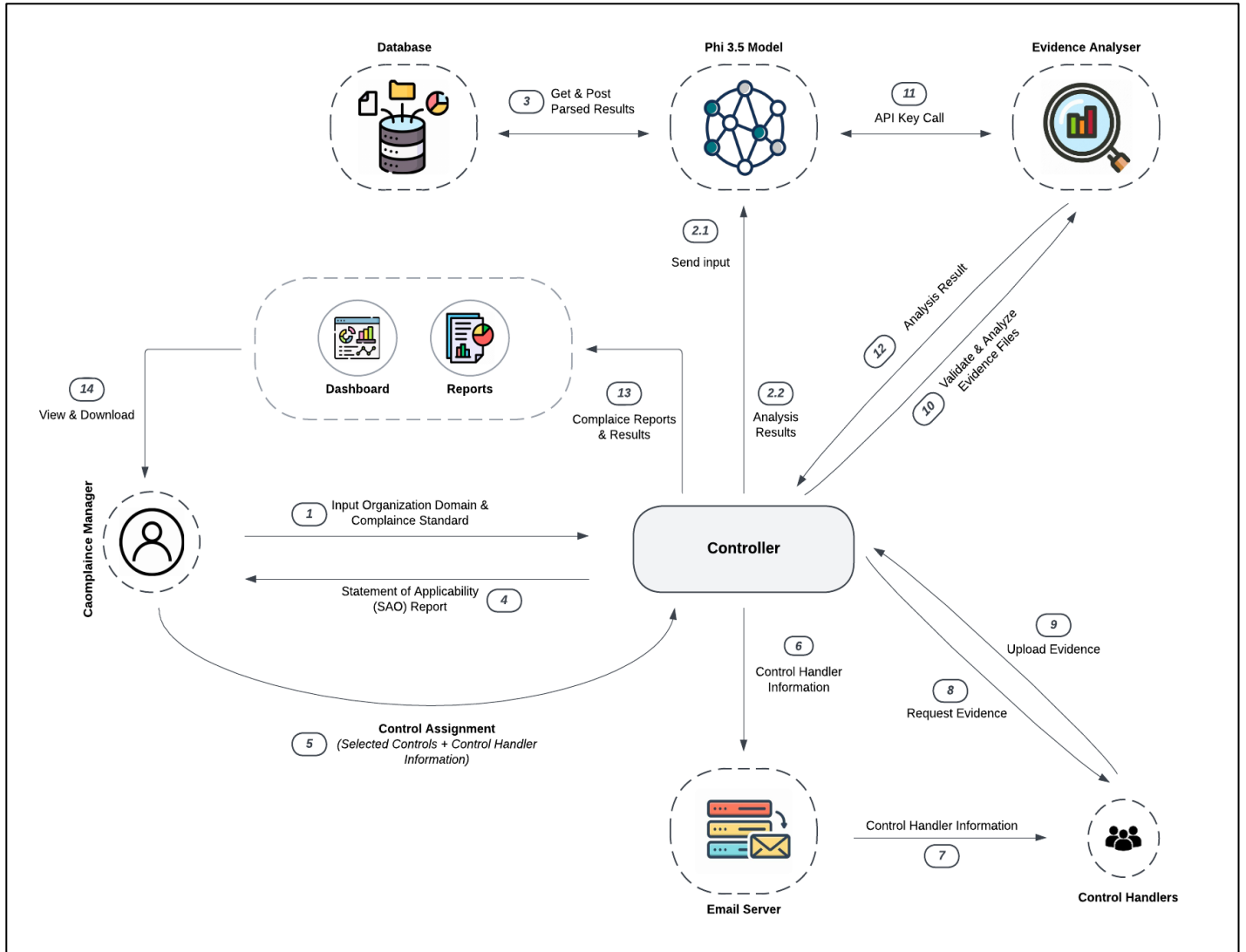


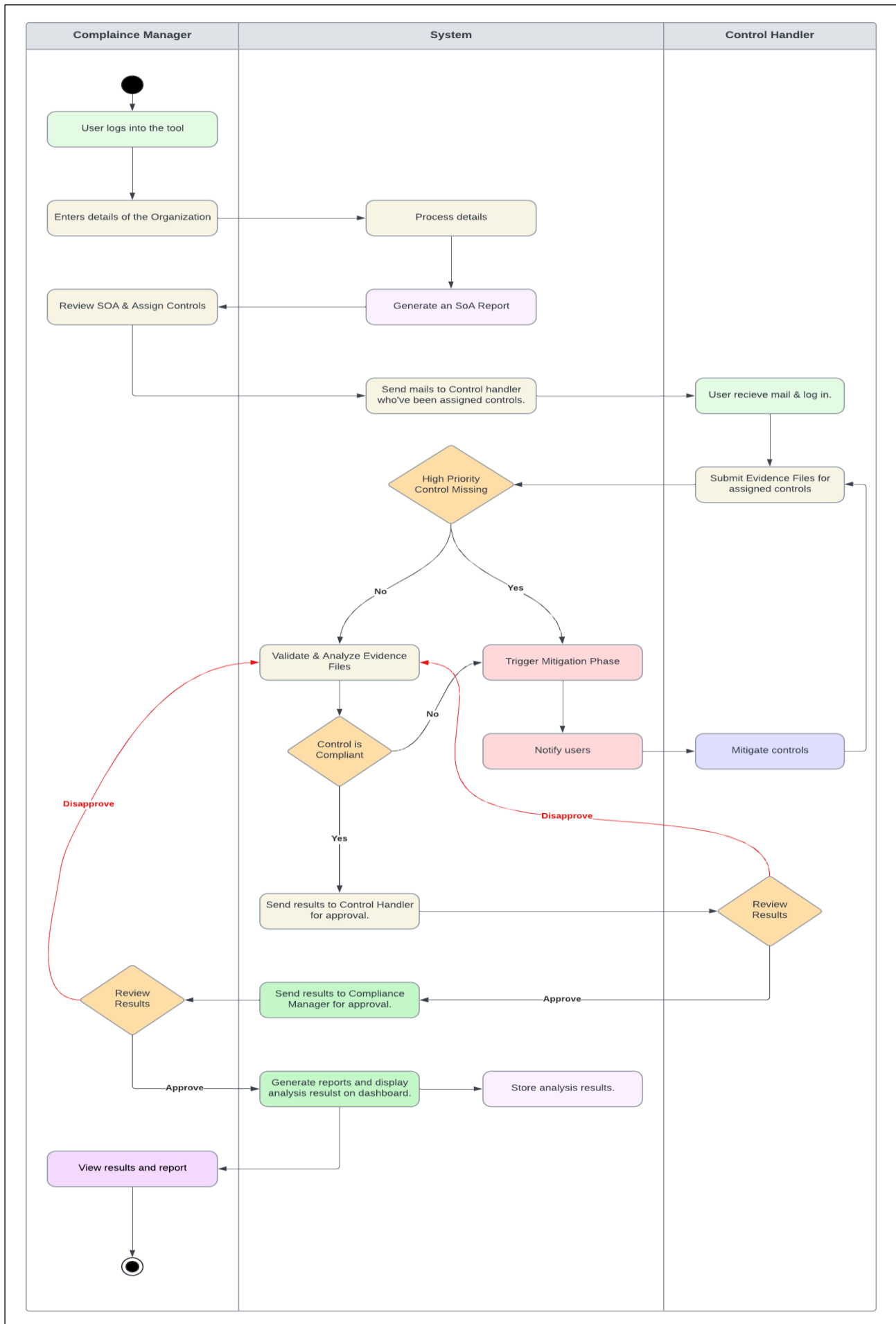
Figure 3. 2 Final Architecture Diagram

3.2 Design Models

For this section, we created design models to provide a clear understanding of the system's structure and functionality. These models include the Activity Diagram, Data Flow Diagram (Level 0 and Level 1), and System-level Sequence Diagram. Each model serves a specific purpose and helps in visualizing different aspects of the system.

3.2.1 Activity Diagram

Figure 3. 3 Activity Diagram



3.2.2 Data Flow Diagram

The Data Flow Diagrams (Level 0 and Level 1) represent the flow of information within the SYNTRA system.

1. Level 0 DFD:

This system diagram gives an overview of the major processes, external entities, and data stores as part of a high-level perspective. Here, this system would interact with some big external entities such as Compliance Manager, Control Handlers, Admin, and Model Server. Major processes comprise user registration, submission of evidence, compliance analysis, and report generation. The DFD very clearly shows how data will flow between these entities and what these core functionalities of the system are doing.

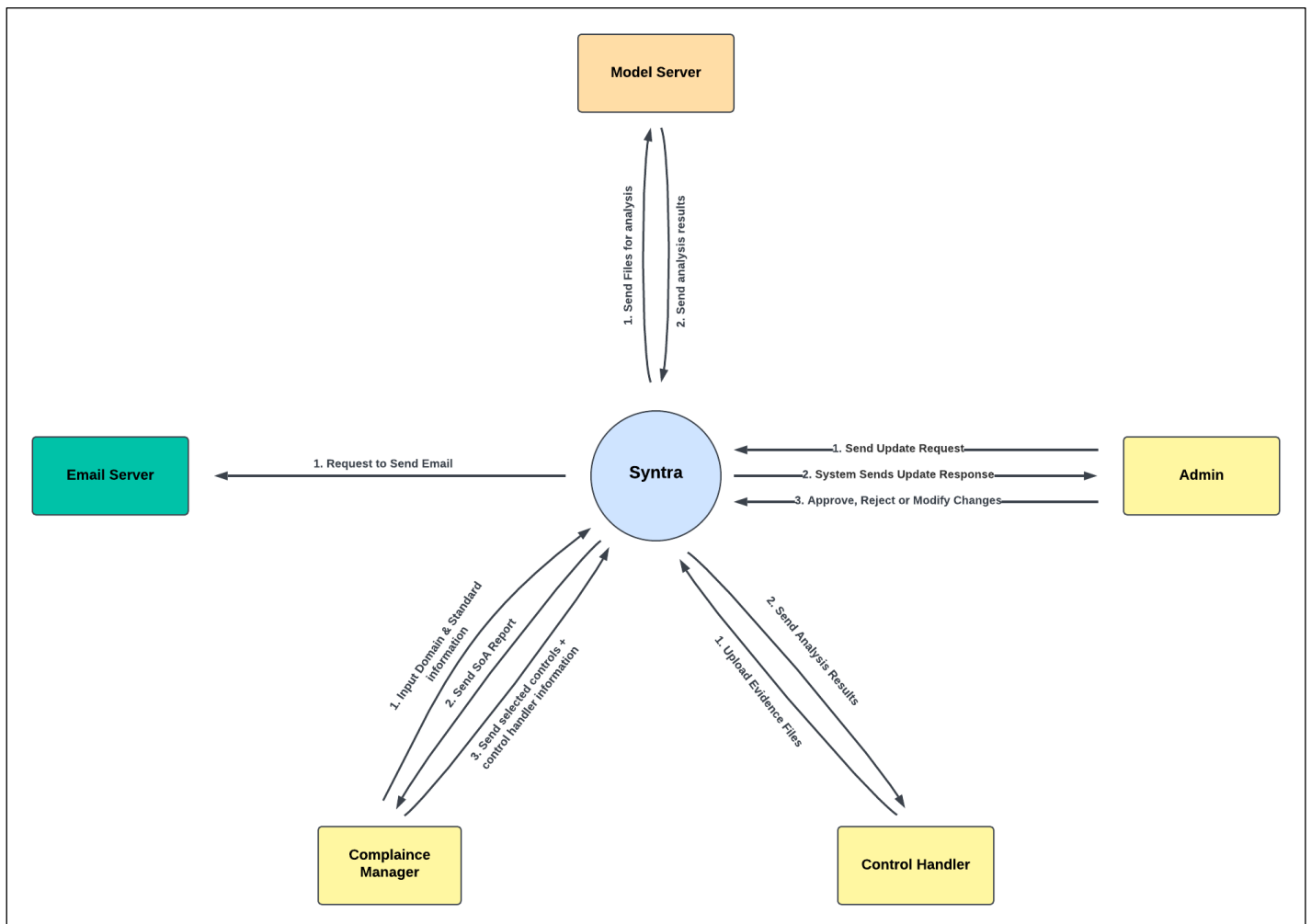


Figure 3. 4 Level 0 Data Flow Diagram

2. Level 1 DFD:

This diagram further extends the Level 0 DFD by showing individual processes of the compliance management workflow. It breaks major processes into sub-processes, including data flow from one to another and specifying data stores for evidence, reports, and user information. Informational level provides more insight into what happens inside the system and how different processes are interrelated.

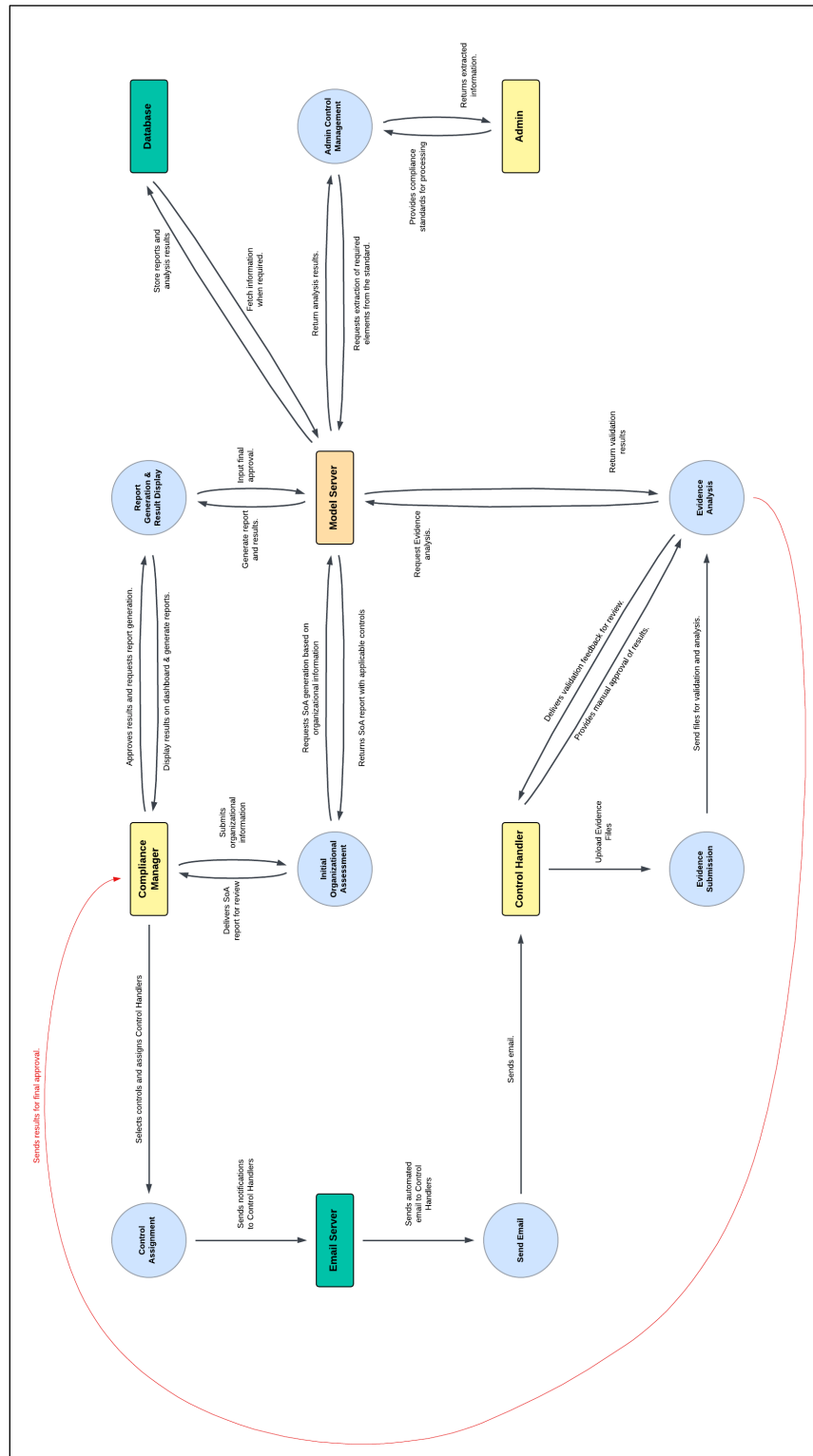


Figure 3. 5 Level 1 Data Flow Diagram

3.2.2 System Sequence Diagram

System sequence diagrams describe how actions should flow between the different components of the system while performing the most important operations in compliance management. SSDs are developed as two independent, completely different workflows- on the client side along the Compliance Manager and Control Handlers, and on the admin side along the backend processes of the system.

1. Admin Side SSD:

The admin-side SSD illustrates interactions between the Admin, System, Model Server, Database Server, and Email Server during the execution of the system at the backend side as well as providing admin oversight. This diagram focuses on the validation of the system, report management, and the control of user and compliance data.

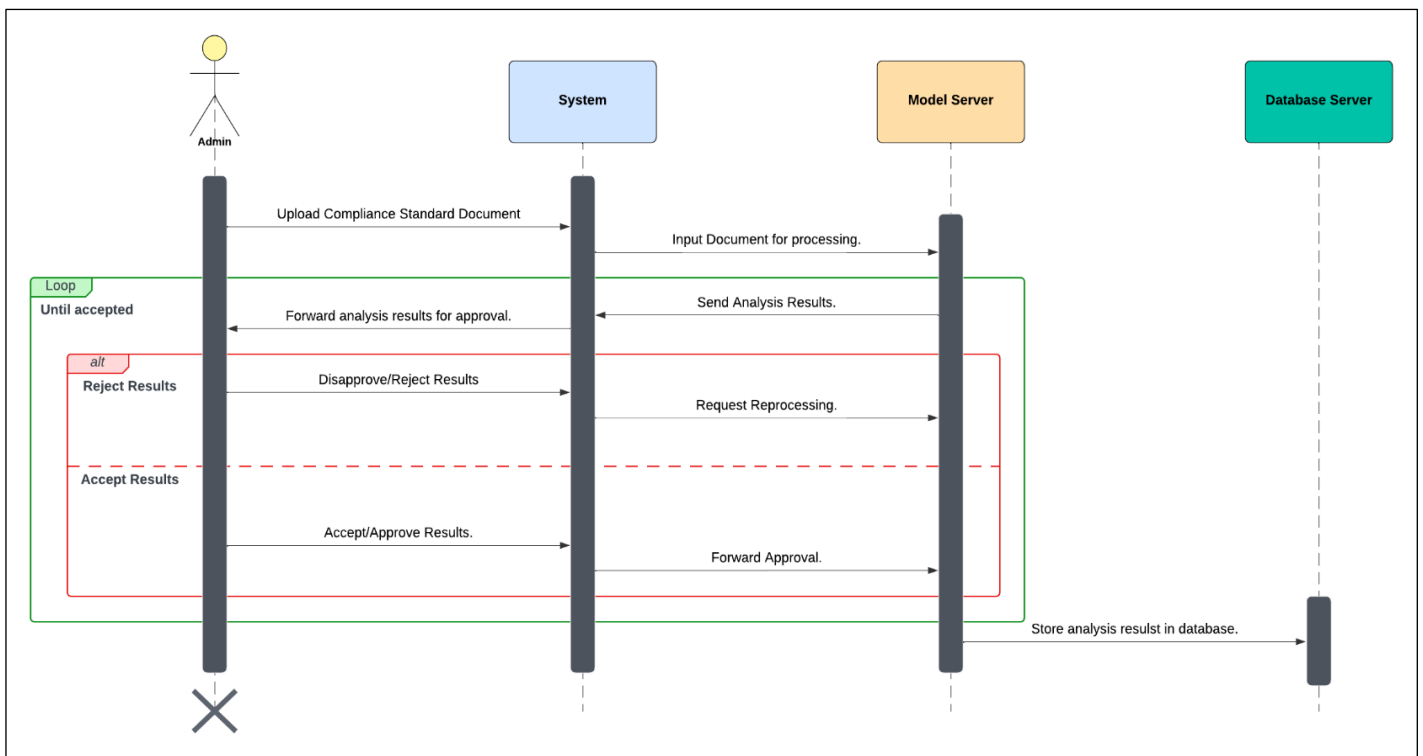


Figure 3. 6 System Sequence Diagram (Admin Side)

2. Client-Side SSD:

The client-side SSD describes the interactions between the Compliance Manager (CM), Control Handlers (CHs), the System, the Model Server, the Database Server and the Email Server.

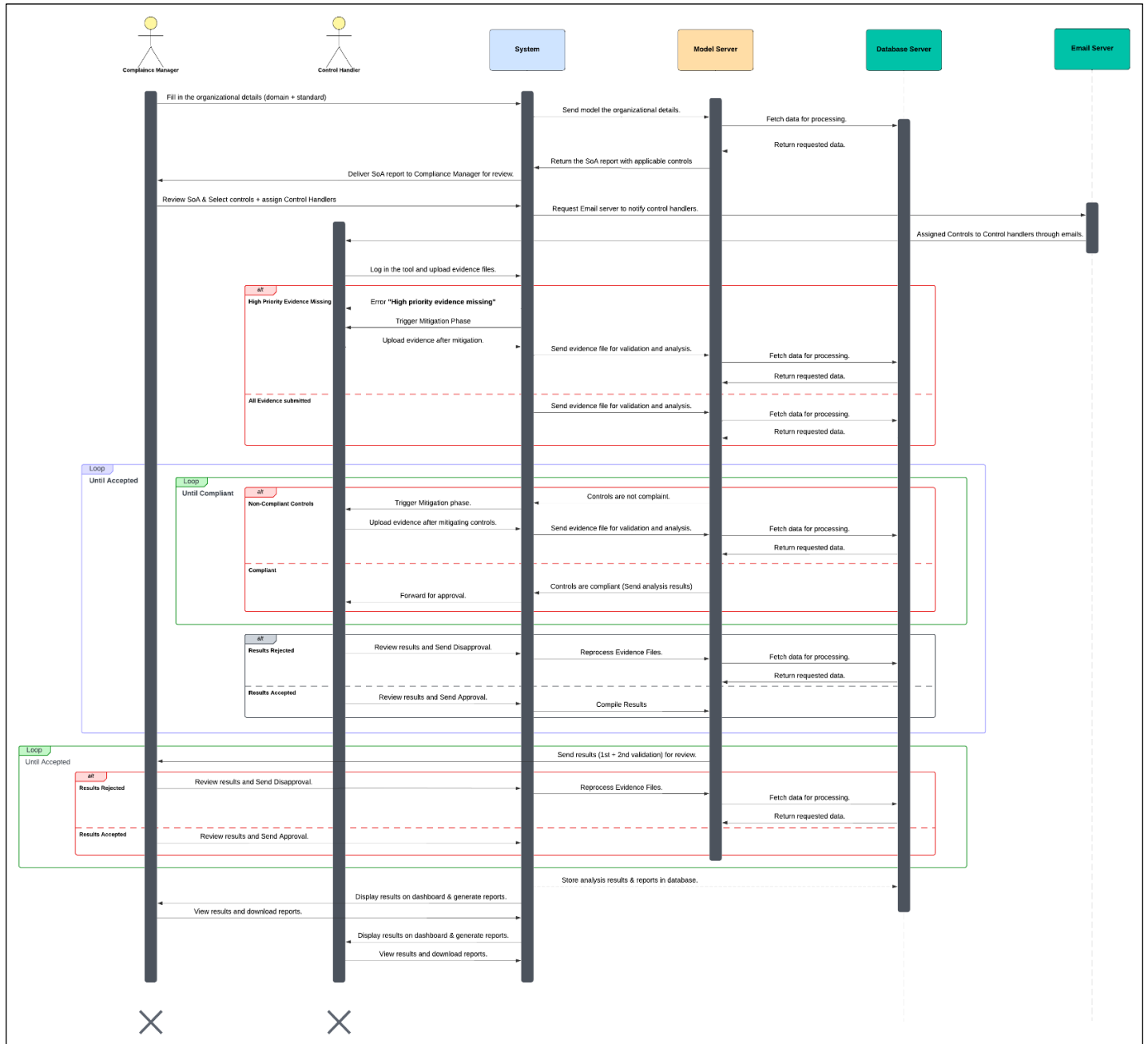


Figure 3. 7 System Sequence Diagram (Admin Side)

3.3 Data Design

In SYNTRA, data design is an essential aspect that ensures proper storage, organization, and retrieval of compliance-related data. This section outlines how the information domain is transformed into data structures and how various system entities interact with databases and storage mechanisms.

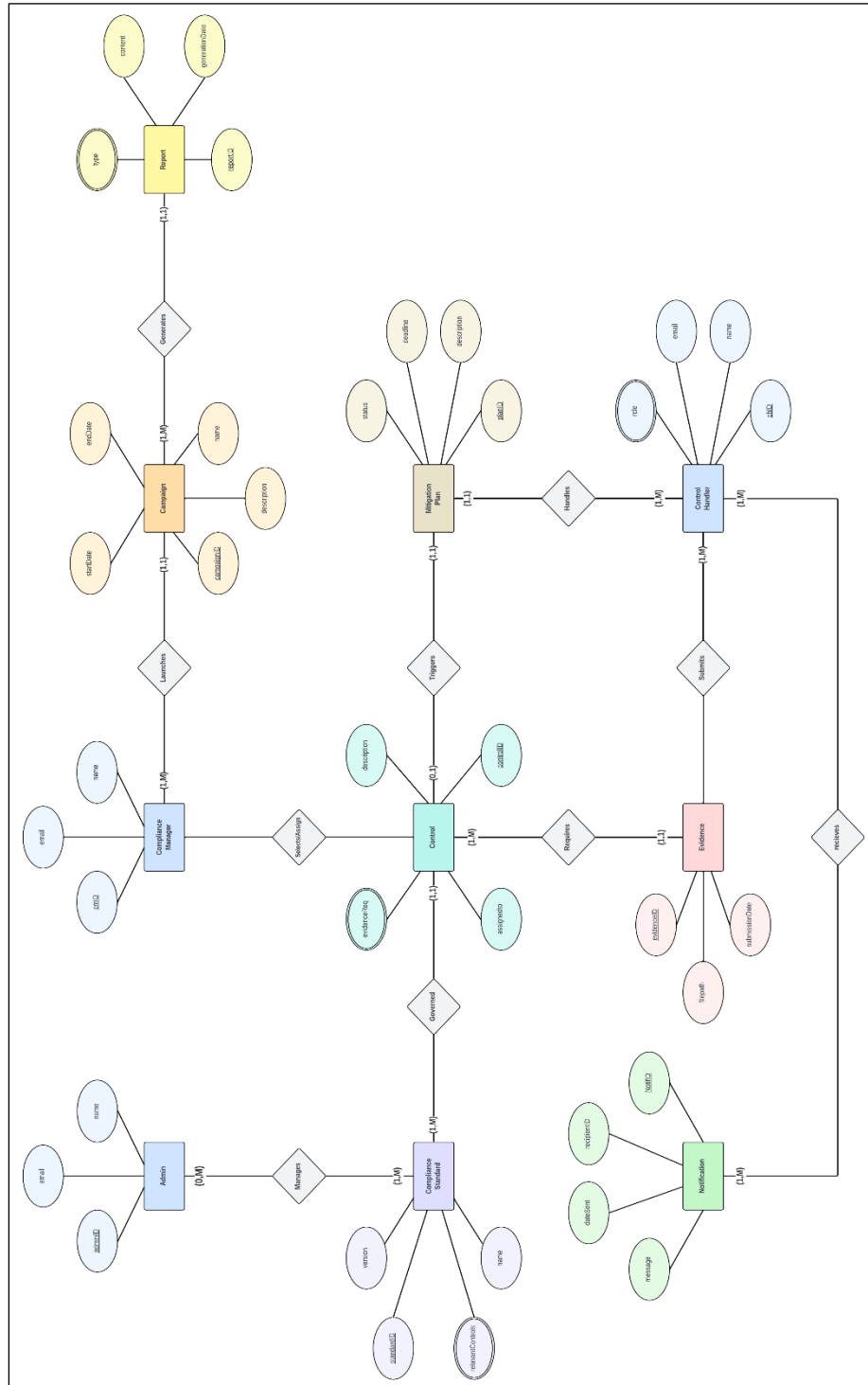


Figure 3. 8 Data Design (ERD)

References

- ISO/IEC 27001 Third edition (2022-10)
- ISO/IEC 27002 Third edition (2022-02)
- ISO 27001:2022 Audit Checklist (Part 2) A.5 Organization Controls